

FROM DECISION TO CONTROL

The Expert Corpus

What must be true of the layer beneath a board's decision

Twenty-seven principles for the machine layer of governance

AUTHOR	Dr. Jack Hong, Terrene Foundation
STATUS	In force. This corpus has standing over every Terrene Foundation specification. A specification answers to it; it describes no specification.
VERSION	1.0 September 2026
LICENSE	CC BY 4.0
SERIES	Terrene Foundation White Paper

The Expert Corpus: From Decision to Control

What must be true of the layer beneath a board's decision

Dr. Jack Hong, Terrene Foundation · Version 1.0 | September 2026 · CC BY 4.0

What this is, and what it is not

This is a statement of what must be **true** of the layer beneath a board's decision. It is not a specification, and it is not a description of one. It sits one level above the Terrene Foundation's published standards, and those standards are written from it — first principles, then requirements, then specifications, in that order and not the reverse.

It is written to be read by a director. Where a principle needs a term of art to be testable, the term is in the failure line, not in the principle.

Its authority is narrow and the narrowness is the point. What a director's duty requires, what a board must be able to evidence, and what a regulator or an underwriter or a court will accept are settled by people who govern for a living, and they are settled first. This document answers to that, and never the other way round. Four things a board must attend to are deliberately outside it, and they are named in § *What this document does not claim*.

Provenance. The Foundation holds this corpus as an anchor document, established 26 August 2026, with the present set of principles established on 27 August 2026. Each principle's statement, body and failure line here is the anchor's text, character for character; where the two ever differ, the anchor governs. Two passages reproducing text from an unpublished third-party document have been removed for publication and one passage discussing that document shortened; where an idea from it remains, the attribution remains with it. Nothing else was altered.

The distance between a decision and a control

A board decides. Somewhere below the board, a system acts.

Between those two events there has always been a gap, and for most of corporate history it was filled by people: a manager who understood the intent, a process that carried it forward, a colleague who would have said something if it went wrong. Governance worked because the distance between the decision and the act was crossed by judgment at every step.

Agentic systems close that distance to nothing and remove the judgment along the way. A system that initiates rather than recommends acts in the interval between board meetings, at a volume no committee reads, on an authority granted once and thereafter assumed.

The decision the board made is still on the record. **Whether it is still in force is a different question, and it is the one that matters.**

Who is writing, and what we are for

The Terrene Foundation publishes open standards for machine-enforceable governance under Creative Commons Attribution, with a reference implementation under the Apache licence. It is a Singapore company limited by guarantee, governed by a constitution. **It sells nothing** — no services, no consulting, no training, and no certification of any organisation's compliance with any law. There is accordingly no revenue that vendor neutrality would cost it.

What it is authoritative on is narrow, and the narrowness is the point: **whether a constraint a board approved is actually enforced, whether the record of it will hold, and whether it behaves identically in two implementations from different vendors.**

An interest, disclosed here rather than somewhere a reader would have to go and look for it. The author of this document writes specifications that the Foundation owns and publishes. Services against those specifications are delivered by several independent commercial entities, and the author holds a material interest in one of them. He holds no interest in the others, and the Foundation holds no interest in any of them. This is stated on the artefact because a reader weighing whether a specification was written to be met or written to be sold should not have to find that out from an annual report.

Where the authority runs

Governance expertise is upstream. What a director's duty requires, what a board must be able to evidence, what a regulator or an underwriter or a court will accept — that is settled by people who govern for a living, and it is settled first.

***Governance expertise** establishes what must be true. **These principles** state what must then be true of the machine. **The specifications** define the exact contract an implementation must meet. **The software** implements the contract as working parts.*

A principle here never tells governance what to require. It answers.

The standard we hold ourselves to

A framework that can absorb every outcome as confirmation is a belief, not a governance instrument. So this document states what would show it wrong (§ *What would falsify this*), states its limits where it has them, and **cites the prior art it rests on rather than claiming it**.

Seven of the principles below rest on settled practice in other fields — authority attenuation from capability-based security, least privilege from operating-system design, the limits of rule-following from safety science, tamper-evident attributable evidence from digital time-stamping and remote attestation, requirements traceability from safety-critical avionics, auditability of an authority against its own will from Certificate Transparency, and purpose limitation from data-protection law. Each says so where it stands. A board-facing document gains authority by showing that what it asks for is already the settled practice of aviation, operating systems and evidence law, not a novel demand.

The question this document asks

A board approves a constraint. This document is an answer to the question that comes immediately after the approval and is almost never asked of the layer below: **what is actually holding it?**

There are three answers, and only one of them is a control.

First, the term the whole thing turns on. **The governed component** is whatever the constraint is meant to bind — a model, an agent, a workflow, a service. Not “the system”, which is ambiguous exactly where it matters.

Stated	Written in a policy.	Holds while people remember it and choose to follow it.
Instructed	The governed component has been told.	Holds most of the time — and degrades exactly when volume and novelty are highest.
Enforced	Held by a component the governed component cannot modify, disable or bypass at run time.	Holds whether or not the governed component is attending to it.

That definition is what makes the ordinary case decidable. A hard limit in an agent’s own tool wrapper, in the same process, that the model cannot alter, is **Enforced** — it is outside the governed component even though it is inside the deployment. A limit in the prompt is **Instructed**, because the thing it binds can rewrite it.

Evidence is a second question, not a fourth rung. Whether a constraint is *observable to an outsider* crosses all three rungs independently: a tamper-evident log with no limit enforced is evidenced and unenforced; a payment gateway with no record is enforced and un-evidenced. Treating evidence as the top of one ladder hides both cases. **A constraint a board can rely on is Enforced and evidenced** — two properties, and the second is section VI.

A human approval gate sits on this ladder conditionally, and principle 11 is what decides where: it is Enforced only where the reviewer has capacity to deliberate. Where the review rate exceeds that, it is Instructed with a signature attached, which is worse than nothing because the signature reads as judgment.

The device of placing governance on a ladder is not this document’s, and the attribution matters: it follows a framing used by Elizabeth Fong and Von Leong in their work on board-level AI governance. What belongs to this document is only what the rungs are, and where the discontinuity between them falls. The two ladders are not the same shape and are not meant to be — theirs places a whole organisation on one axis, this one places a single constraint.

The discontinuity is between Instructed and Enforced. Below that line the constraint depends on the thing it constrains. Above it, it does not. Every principle in this document is either an argument for crossing that line or a statement of what crossing it requires.

And the drift runs downward, where it is least visible. A rule written into a policy is copied into a system prompt; the prompt is edited; the edit is not reviewed because it was not a policy change. Nothing was approved, and the constraint moved from Enforced to

Instructed.

The principles

Twenty-seven, in six groups. Each states what must be **true** — not how to build it. The mechanism is a specification's job, and specifications are written from these, not the reverse.

Each carries the test that makes it an authority rather than an essay: **what a specification does that fails it**. A principle nothing could fail is a description, and descriptions do not govern — so if the failure line under a principle reads as untestable, the principle is not ready.

The document also uses the governed component's own vocabulary sparingly and deliberately. Where a principle needs a term of art to be testable, the term is in the failure line, not the principle.

I. Authority

1. Accountability resolves to a person who has accepted it. There is no action an organisation takes that does not resolve to a named person answerable for it. Accountability is a status only a person can hold. And it begins with **acceptance**, not assignment: a person named without accepting has been recorded, not made accountable — which is the difference between an organisation chart and a governance structure. The answerable position persists when the seat is empty, so a reorganisation cannot silently orphan responsibility.

The chain terminates where this document's competence does. Every step below the apex governance body resolves to someone, and the chain reaches that body rather than trailing off before it. Above it, the question is whose duty a collective decision is — and that is the first thing this document declines to answer. A design that carries the chain to the apex and stops there, saying so, has met this requirement. One that stops earlier, or leaves unstated where it stops, has not.

A specification fails this when a structure is permitted in which some action resolves to no named role, or assignment is treated as sufficient without a recorded acceptance.

2. Authority narrows as it passes, and ends when its source ends. An actor granting authority to another may grant less than it holds, never more, at every depth. And a grant that survives the withdrawal of the authority that made it is not delegated authority — it is independent authority, acquired quietly.

Prior art, and we claim none. This is attenuation from capability-based security. Capabilities as unforgeable, transferable references to authority are Dennis and Van Horn (1966); least privilege is Saltzer and Schroeder (1975), stated there as a design principle. **The revocation clause is the older half, not the sharper one:** Redell (1974) described the forwarder/revoker pair, and Miller, Yee and Shapiro (2003) restate it and show that revoking at the source cascades to everything re-delegated beneath it. What is new is only the setting.

It is also now set out by a regulator in its own words. IMDA's *Model AI Governance Framework for Agentic AI* (v1.5, 20 May 2026, updated 5 June 2026) — **a voluntary framework, not a binding instrument** — states as a rule of thumb that a human user should not be able to set permissions for an agent greater than the human is himself authorised to hold, and that such delegations should be clearly recorded; and that authorisations should generally be scoped, time- or session-bound, non-transferable, and least-privilege by default. **It states this for the human-to-agent grant.**

What is genuinely unsettled is the upper end of the chain, and it is the more important half. The capability literature governs authority over objects held by processes. It has no account of an authority whose grantor is a deliberative body, whose scope is written in natural language, and whose validity depends on facts outside the system — a resolution still standing, a delegation not yet rescinded, a regulatory permission still current. **Mapping an organisational mandate onto an attenuable machine authority, and stating what must hold for that mapping to remain faithful, is not in that literature.** The board's question is not whether authority attenuates correctly between processes. It is *does the machine still hold the authority we actually granted, now that the resolution behind it may have lapsed.*

*A specification fails this when any grant may convey more than the granter holds, at any depth, or a grant survives the **withdrawal or lapse** of the authority that made it, or **authority may be held by a component with no grant that conferred it.***

3. What a system may do is decided by the organisation, not assessed by the system. A system must not extend itself into work it was not given. Which of its systems handles which kind of work is the organisation's decision and belongs in the organisation's own record; a remit the board approved that the system assesses for itself is not a remit.

The boundary is crossed by addition, not by breach. A capable system is asked, in good faith, for the adjacent thing. No single request is unreasonable and none of them is large; what nobody approved is the sum. And because nothing marks the crossing, a remit examined after the event is a remit that was already left behind — which is why it has to be a standing declaration, with a date on it, tested before the action rather than reconstructed after it.

The exposure is the board's, not only the deployer's. Under the EU AI Act the intended purpose of a system is a legal attribute rather than a description. Article 25(1)(b) and (c) convert a deployer into a **provider**, carrying the full provider obligation set, where it makes a substantial modification to a high-risk system or modifies an AI system's intended purpose such that the system becomes high-risk. The Regulation names the consequence and leaves the detection to the organisation, on the assumption that a change of purpose is something a person decides. A system that widens its own remit changes purpose with nobody deciding, and the obligations arrive without the decision that would have signalled them.

The regulators are converging on this and stop short of the same line. MAS's proposed guidelines on AI risk management — **a consultation paper, not an issued rule** — require an inventory carrying each system's approved scope of use, and say what the inventory is for: “*monitoring of scope adherence*”. IMDA's agentic framework — **voluntary** — reaches the same point from the run-time side, listing among its default-deny conditions the case where agents attempt new actions with no established approval policy in place. Both name the requirement. Neither says what a declaration must contain, when it must be tested, or how someone outside the deployment establishes that the test ran.

A specification fails this when the governed component may determine its own scope, or routing is left to its judgment.

4. Access follows the work, not the rank. What a person or a system may know is set by what the work requires, not by seniority. Rank-indexed access is the most common way an organisation discovers it had no access policy at all.

A specification fails this when access is indexed to seniority, or there is no way to express access as a function of the work, or a record may be released outside the organisation without a stated recipient purpose that fixes what it contains, or two releases may be joined — by one recipient across records, or by two recipients between them — to recover what neither purpose required, or the period a record may be disclosed is not stated independently of the period it is retained.

25. An authority is measured against the work it is for, not against what the approver could have granted. An approved authority states what a system may do. The question a board must be able to ask of it is not whether it was within the approver's gift — it always is — but whether it is the authority the work requires. A grant wider than the work is not a latent risk that becomes real if something goes wrong; the width **is** the exposure, and it is exposure the board approved. And the grant must be closed rather than merely capped: an authority expressed only as a ceiling has set a limit on the size of what a system may do and none on the kind.

Prior art, and we claim none. Least privilege is Saltzer and Schroeder (1975), stated there as one of eight design principles: “Every program and every user of the system should operate using the least set of privileges necessary to complete the job.” NIST SP 800-53 Rev. 5 carries it into the control catalogues as AC-6 and extends it explicitly to system processes. IMDA's *Model AI Governance Framework for Agentic AI* (v1.5, 20 May 2026, updated 5 June 2026) — **a voluntary framework, not a binding instrument** — states that “Authorisations should generally be scoped, time- or session-bound, non-transferable, and follow the principle of least privilege by default”. It is fifty-one years old and it is settled engineering.

What is not settled is the datum. In an operating system the job is a program's permission set and the comparison is mechanical. An organisation's work is a remit written in a sentence, and the comparison is possible only if that sentence is part of the approved instrument rather than context around it. An authority with no statement of what it is for cannot be found too wide, because there is nothing for it to be too wide against — which is why most authority positions are not generous but unfalsifiable.

And the work moves while the grant stands. A capable system is asked to do adjacent things by people acting in good faith; each addition is small and separately defensible, and the sum is an authority nobody approved. So the comparison is not discharged at approval. It is owed again whenever the grant changes or the work does.

Distinct from principle 2, and the distinction is the whole of it. Principle 2 bounds a grant **relative to its granter** — never more than the granter holds, at any depth. That bound is satisfied at any width by an authority that holds enough, which is what an apex body does. Principles 13 and 20 bound **departures** from the approved position and principle 19 asks where it is in force; all three take the approved position as their datum, and so none of them can report that the datum itself is wrong.

A specification fails this when an authority may be approved with no statement of the work it is for, or may be expressed as a ceiling with no enumeration of what falls inside it, or need not be re-measured against that statement when either changes.

26. An authority narrower than the work it is for is a failure of the authority, and the only failure of authority that has to be looked for to be found. A board approves an authority in order to prevent a class of harm. The authority it approves is also, at the same moment, the whole of what the position beneath it is now able to do. Set below the work, it does not produce caution. It produces a position that is still accountable for an outcome and no longer able to reach it — and the accountability does not lapse because the means did.

A narrow authority is not the safe error. It is the one that reads as safe. An authority set wider than the work is understood by every director present to be an exposure, and it is minuted as one. An authority set below the work is minuted as prudence, and the work that does not happen under it is not an event. There is no incident report for a decision that was never taken, a payment that was never released, a customer who was never answered. The failure is real, it is the board's, and it is invisible in precisely the register the board reads.

What has changed is that nothing now absorbs it. For as long as delegation ran to people, an authority narrower than the work was corrected on the floor. The person under it exercised judgment, took the sensible route, and got the outcome the grant had failed to describe — and in doing so silently repaired the instruction. That correction was never a governance mechanism anybody designed, and it was never recorded, but it was load-bearing: it is the reason a badly drawn authority has historically been survivable. It is the reason **working strictly to rule is a recognised way to bring an organisation to a halt** — following the written instruction exactly is the exception, and it is disruptive enough to be a bargaining tactic.

A machine under an authority works to rule by construction. It takes no sensible route, because the grant is the whole of what it can reach and it has nothing at stake in reaching further. The correction that used to happen quietly does not happen at all, and the signal that used to accompany it — the complaint, the exception request, the workaround somebody noticed — does not arrive. **The organisation has lost its detector for its own over-constraint at the same moment it lost its absorber.** That is why this has to be built rather than trusted to surface.

The organisation must therefore be able to say what the work under an authority minimally requires, in the same instrument that grants it, and be told when the grant has fallen below that statement. **This asks for something a statement of purpose**

does not supply. Saying what an authority is *for* is what makes it possible to find the grant too wide. It does not yield the floor beneath it: knowing that a role exists to pay suppliers does not say what authority paying suppliers takes. The two statements are different statements, they are established at different moments, and an organisation can hold either without the other. The floor is the one that has to be added.

Where no such floor has been stated, the extreme case remains detectable without one: an authority that permits no action at all is inoperable on its face, and needs no comparison to be recognised as such.

And what is detected is reported upward, never enforced against the action. A narrow authority is very often the correct one, and a mechanism that stopped work on suspicion of over-constraint would be the failure it was built to find. The finding goes to the authority that made the grant, because that authority is what has to change.

Prior art, and we claim none. That people do not follow instructions to the letter, and that this is adaptive rather than delinquent, is settled in safety science. Rasmussen (1997) states it flatly — “rules, laws, and instructions practically speaking are never followed to the letter”, with “working-according-to-rules” named as the form a strike takes — and treats operators’ departures from formal rules as “quite rational, given the actual work load and timing constraints”, on the ground that the rule-writer “cannot, however, foresee all local contingencies of the work context”. His conclusion is about measurement: “A task instruction thus is an unreliable standard for judging behaviour in actual work.” **What is new is the sign of that conclusion at the machine layer.** For a person, the gap between the instruction and the work is absorbed and hidden. For a machine, the instruction is the work, so the same gap is neither absorbed nor hidden — it is executed. The literature explains why the tightness of a rule is invisible in a human organisation. It has no account of an organisation that has removed the thing doing the hiding and gained nothing in its place.

The instruments name the datum and stop there. The EU AI Act requires that “The oversight measures shall be commensurate with the risks, level of autonomy and context of use of the high-risk AI system” (Art. 14(3)) — a two-sided standard, since a measure can miss commensurate from either direction. The Regulation attaches a conformity route to oversight that is too little and nothing at all to oversight that is too much, and specifies nothing that would detect the second. The NIST AI Risk Management Framework — **voluntary** — comes nearest to naming the cost: “Attempting to eliminate negative risk entirely can be counterproductive in practice because not all incidents and failures can be eliminated”, and “Unrealistic expectations about risk may lead organizations to allocate resources in a manner that makes risk triage inefficient or impractical or wastes scarce resources”

(§1.2.3). That is a statement about how an organisation spends its risk budget. It is not a statement that an authority can be set past the point where the work stops, and neither framework asks anyone to look.

A specification fails this when a granted authority may be approved with no statement of what the work under it minimally requires, or may be narrowed past that statement — or to a state in which no action at all is permitted — with nothing reporting it, or that report is enforced against the action rather than raised to the authority that granted it.

II. What makes a constraint real

5. A constraint that depends on the thing it constrains is not a constraint. A rule a component is merely told to follow is a rule it follows most of the time, and most of the time is not a control. The constraint must be held by something the governed component cannot modify, disable or bypass, so that it holds at the end of a long piece of work exactly as it held at the start.

A specification fails this when the only enforcement point lies inside the governed component, or that component may alter the constraint at run time.

6. A party that bears no consequence cannot be its own control. A system optimising for completing its task is not indifferent to the constraint — it is opposed to it, structurally and without intent, because every safeguard is a detour. This is not a claim about misbehaviour. It is a claim about what a thing with no stake will do at a fork.

Distinct from principle 5, deliberately. Principle 5 says a constraint must not depend on the governed component's **memory**; this says it must not depend on its **incentive**. Either could hold without the other. Principle 7 is the third axis — **time** — where the interval in which a wrong outcome could still be corrected has closed.

A specification fails this when the governed component is designated the verifier of its own compliance.

7. Where an action is irreversible within the detection-to-correction interval, detection is not a substitute for prevention. The established control objective, in ISAE 3402's words (¶A25, ¶A28), is that misstatements be “*prevented, or detected and corrected*” on a timely basis. **Detective controls are controls in good standing** — COSO's taxonomy is two-valued with no hierarchy, and ISO/IEC 27002:2022 makes Preventive / Detective / Corrective a formal attribute of every control. Nothing here disputes that. The

point is narrower: the objective is discharged by detection **coupled to correction**, and that coupling was calibrated to a reporting cycle, in which detection followed by correction before the accounts issue really is equivalent to prevention. An agent taking an irreversible action in milliseconds collapses the interval in which correction is possible. **The claim is not that detective controls are lesser; they are controls in good standing. The claim is that the window the frameworks assume has closed.**

A specification fails this when an irreversible action may proceed on a detective control alone, with no correction path inside the window in which correction is still possible.

8. A required control that can be absent is not required. Where a human decision is required before something takes effect, a system with no such decision step in place must refuse to run rather than run without one. A control that exists only where somebody remembered to switch it on is not a control a board can rely on.

Its pair is principle 12. Both say that a required human decision which is not available must never resolve as permission. This is the configuration-time case — the gate was never put in place — and it is ours. Principle 12 is the run-time case — the gate is there and nobody answered — and it is Fong and Leong's.

A specification fails this when an implementation with no decision step in place may run rather than refuse.

9. A control that has never been exercised is not known to work. A stop, a fallback, a containment path — anything whose whole purpose is to fire in a situation that has not yet arisen — must have been exercised deliberately, with a date, or the organisation knows only that it exists. Least privilege and a way to stop are the two constraints most often designed and never tested.

A specification fails this when it requires the mechanism to exist and requires no evidence that it has ever operated.

Prior art, and it is deep. Process-safety practice has required **proof testing** of protective functions that never fire in normal operation for decades (IEC 61511 / IEC 61508), with the test interval itself a design parameter. Nothing in AI governance has adopted it.

And this is a gap in the landscape, not a preference. Every instrument in it requires the stop to **exist**; none requires evidence that it **works** — OECD 1.4(b) hedges it three times; the NIST Generative AI Profile requires protocols to be in place; the EU AI Act Art. 14(4)(e) requires a stop button reaching a “safe state” and defines neither the safe state nor who deter-

mines it was reached. NIST AI RMF MANAGE 2.4 comes closest — mechanisms “*in place and applied*” — and it is voluntary and unmeasured. For an agent with external side effects, **halt** and **safe** are different properties, and no instrument distinguishes them.

III. Where judgment is spent

10. The governing act is setting the limits, not approving the instances. Judgment does not scale; checking does. A design that spends judgment on every instance has mispriced the scarce input, and will run out of it precisely when volume rises.

A specification fails this when per-instance approval is the primary control for a class of routine actions.

11. A review that exceeds the reviewer’s capacity to deliberate produces ratification, not oversight. This is narrower than it first appears, and deliberately so. Mandated approval gates work: drug approval and financial controls testing process real volume with real scrutiny. **The objection is not to approval as a category — it is to volume.** Where the rate of review exceeds what a reviewer can consider, the control silently becomes a signature, and the organisation is more exposed than if it had none, because the signature is treated as evidence of judgment.

Prior art, and it is against the naive form of this claim. Green (2022), surveying 41 policies requiring human oversight of government algorithms, finds that they are unsupported by the evidence and **legitimise the systems they purport to check**. The automation-bias literature runs from Bainbridge (1983) onward. The EU AI Act Art. 14(4)(b) requires an overseer to “*remain aware*” of automation bias, which is an instruction not to have a cognitive bias. **Requiring oversight is not the same as having it, and a requirement that cannot be evidenced makes things worse.**

A specification fails this when review is mandated with no means of expressing or reporting review volume against reviewer capacity.

12. An escalation that expires must never resolve as approval. Anything escalated for human decision carries a deadline. An unanswered escalation must end in refusal or in a higher hand — never in permission. Human unavailability is not consent, and a clock is not a decision-maker.

This condition is Elizabeth Fong and Von Leong’s, and it is adopted here as they state it. The formulation is theirs.

Two of the Foundation’s published standards currently permit the opposite [disclosure]: `eatp/03-operations.md` allows auto-approve on timeout provided a flagged record is written, and `care/01-philosophy/01-first-principles.md` allows it as an organisational policy choice. **Both change. The principle governs, not the specifications.**

What is missing is that no binding instrument requires it. IMDA’s agentic framework comes closest and states it for one case — “*Denying action by default when approval infrastructures fail (e.g. when human supervisors are unreachable or agents attempt new actions that do not have any established approval policies in place)*” (§2.2.2, p.30) — and that framework is voluntary. Neither the EU AI Act, the NIST AI Risk Management Framework, the Generative AI Profile nor the OECD Recommendation addresses it, and none of them addresses the state an agent occupies while the escalation is still open. Every timing obligation any of them carries is a **reporting** deadline running against the organisation, not a **decision** deadline running against a human in a control loop. Article 14’s oversight model is synchronous by construction — it has no account of what a system does while waiting, how long it may wait, or what state it occupies if the human never answers. For an agent mid-execution, that is the whole question.

A specification fails this when any timeout path resolves as permission to proceed — including via a disposition whose defined behaviour forwards the action.

13. A granted exemption expires by itself and is counted. An exemption is a bounded, declared, expiring instrument — something the organisation **approved**, which is what separates it from principle 20’s undeclared difference. It never grants more than the person approving it holds; it expires without anyone remembering to end it; it is reviewed; and exemptions are counted, so the pattern every experienced director recognises — granted once, granted again, and by the following year it is simply how things are done — appears as a number before it becomes a custom.

A specification fails this when an exemption may exist without an expiry the system enforces, or without being counted.

14. Removing a control is harder than adding one, and never travels inside a routine change. Withdrawal requires more authority than installation, is open to challenge, and is put to the approver on its own — never carried inside a routine update where an approver would not recognise it as a removal.

A specification fails this when a control may be removed at the same authority that installed it, or inside a routine change.

IV. The written position

15. Silence is not neutrality. Where an organisation's practice differs from the prevalent practice of its industry, the difference must be written into the material its systems read. An unstated position is not absent; it is supplied by whatever convention the system learned elsewhere. What a board governs is the written context, not the capability.

A specification fails this when there is no place to record an organisational divergence, or absence is treated as permission.

16. The rules change only by decision, never by accumulation. Every change to the standing rules traces to a person who decided it. A pattern a system has observed and repeated must never become the organisation's rule by force of repetition, however reliable it looks.

A specification fails this when an observed pattern may become a standing rule without a recorded human decision.

17. One authoritative statement per rule, and no superseded version still in force. When the organisation changes its position, no earlier version may survive anywhere its systems still read, and the organisation must be able to show that no two of its sources contradict each other.

A specification fails this when two sources may state a rule with no precedence between them, or there is no means to retire a superseded version.

18. Whoever holds the context sets a boundary; approval of a change to a governing rule comes from outside the proposer's line. These are two acts, not one, and separating them resolves what otherwise looks like a contradiction. **Setting** a boundary requires context, and context lives with the work — a central body setting boundaries it does not understand produces constraints that are either inert or routed around. **Approving a change** to a rule that binds others requires independence, and a subordinate whose scope the proposer sets is not independent. The authority required rises with how far the change reaches: inside your own scope, you set; beyond it, someone outside your line approves.

A specification fails this when a change to a rule binding others may be approved inside the proposer's line, or boundaries must be set centrally where the centre lacks the context.

V. In force

19. Published and in force are different states. A board must be able to ask, of any position it has approved, which parts of the organisation are operating under it and which are not — and receive an answer. A part that has not taken it up becomes visible within a stated period, either as adopted or as a recorded refusal. A rule that has been published and not taken up is governance on paper.

Principle 20 is what follows. This one is the **state** distinction — published, or in force, and where. Principle 20 is the **disposition** rule for any gap the answer reveals.

A specification fails this when there is no way to determine where a position is in force, or publication is treated as adoption.

20. A difference from the approved position is either declared or is an exception. Every gap between what a part of the organisation runs and what the board approved is one of exactly two things: a recorded, approved variation, or an exception awaiting a named person's decision. There is no third category, and nothing may quietly close the gap without one of the two.

A specification fails this when a difference may be closed without either a recorded variation or a recorded exception.

VI. Evidence

21. A record must be built to be disbelieved, and must state what it does not prove. The record of a governed action must be evidence, not an account. It must remain checkable by a party who was not present, does not trust the producer, and is looking for a reason to reject it. Where the record is produced by the actor it describes, something other than the actor's word must fix it to its origin.

And the bound must travel with the claim. Binding an instruction into a record establishes **which** origin the record is committed to. It does not establish that the origin was genuine: a party holding the signing key can manufacture an instruction and a valid record together, and no signature scheme can prevent that. What it delivers is that the fabrication is **attributable** and cannot afterwards be disowned. That is worth more than the overclaim, and stating it is the difference between a contract a board can rely on and one it cannot.

Prior art: hash-linked, tamper-evident ordering of records without a trusted archivist is Haber and Stornetta (1991); the principles that make an attestation about a remote party mean anything — freshness, target-controlled disclosure, explicit claim semantics under

composition — are Coker et al. (2011). In law, Federal Rules of Evidence 902(13)–(14) on self-authenticating electronic records.

A specification fails this when the record is verifiable only by its producer, or the specification claims a property its own security section disclaims.

22. A control's presence is not evidence that it binds. Only its observed operation is. Governance apparatus fully present on paper and inert in practice is the characteristic failure of this field, and it is not new. Sociology named it *decoupling* (Meyer & Rowan, 1977); audit named it *rituals of verification* (Power, 1997); legal scholarship named it *cosmetic compliance* (Krawiec, 2003) and *legal endogeneity* (Edelman, 2016); security named it *theater* (Schneier, 2003).

What is new is that the gap has become observable. That literature explains why organisations adopt controls that do not work — legitimacy, ambiguity, liability — and presumes the gap between structure and activity is not visible from outside. At the machine layer it is mechanically visible, which changes the equilibrium those accounts describe. That is the contribution, and it is the whole of it.

The strongest objection to this document. Bamberger (2010) argues the opposite: that automating compliance transfers legal interpretation to programmers, masks uncertainty and induces automation bias — that automation makes oversight **worse**. We think observability is the answer to it, and we would rather have that argued now than assumed.

A specification fails this when conformance may be claimed on the presence of a control, with no evidence of its operation.

23. An executed action traces back to the position that authorised it. It must be possible to take any action a system took and follow it back to the approved position that permitted it — and to take any approved position and find what was done under it. A chain that runs only one way finds the actions nobody authorised, and never finds the authority nobody exercised.

Prior art, and we claim none. Bidirectional requirements traceability is mandatory in airborne software and has been since DO-178B (1992), with parallels in the automotive and medical-device standards. **What this adds is the upper terminus.** Those chains begin at system requirements and have nothing above them; a board decision sits above them, and the link from an approved position to the requirement that implements it is the one nobody has had to draw before, because nothing above the system was previously expected to bind it.

A specification fails this when the chain runs in one direction only, or there is no link from an approved position to the requirement implementing it.

24. The authority that sets the rules is itself recorded, and the record is checkable from outside it, against that authority's will. An organisation that instruments what its people do, and not what its rule-setters do, has built surveillance rather than governance. Whatever standard of evidence applies to the governed applies at least as strongly to the governing. **Readable is the floor, not the standard:** a record an outsider can read but cannot check leaves the rule-setter's account of its own conduct resting on the rule-setter's word.

Prior art, and it is exact. Certificate Transparency (RFC 9162) makes a certificate authority's own issuances publicly auditable against that authority's will. It is the one place where this principle has already been built, and it is this principle's direct ancestor.

A specification fails this when the governed are instrumented with no equivalent record of the governing authority, or that record can be read only by that authority, or its completeness rests on that authority's cooperation.

27. A governance record used to manage the individuals it records stops being evidence. The record that shows a constraint held is also, without a single change to it, a per-person account of who did what. Nothing in its construction separates the two readings. The difference is a decision somebody makes, and where nobody makes it the record is available for both.

The reason to make it is not only the obvious one. A record that is read against the people in it stops describing what happened. What gets entered becomes what is safe to have entered; what gets contested becomes what is worth the cost of contesting; and the act a board most needs the record to show — a person objecting to a rule and being overruled — is the act such a record most reliably deters. The failure is silent, because the record still exists, still validates, and no longer means what it did. An organisation that turns its governance record on its people has not traded evidence for control. It has lost the evidence and kept the appearance of it.

The limit is on measurement, not on evidence, and the distinction is the whole of the rule. A record that cannot establish who authorised or accepted a particular action is not a governance record at all — accountability with no possible consequence is a status, not a duty, and the requirements above depend on that use being available. What destroys

the record is the second use: the same material turned into a standing account of how each named person is performing. One is a proceeding about an act. The other is an instrument pointed at a person, and it is the instrument that changes what gets written down.

And this is the price of the requirements above, not a qualification of them. A record built to be disbelieved is built to be complete, and completeness is precisely what makes it usable as a standing measure. The limit on its use is the condition on which the evidence requirements can be met at all: an organisation that cannot bound the second use will, correctly, build a thinner record.

Principle 4 is the neighbour, and the line between them is worth stating. That one fixes what a party may know. This one fixes what may be done with what it already knows. A record perfectly indexed to the work engages only principle 4; the same record turned into a quarterly ranking engages only this one.

Prior art, and we claim none. Purpose limitation is settled law and considerably older than the machine layer. Regulation (EU) 2016/679 Article 5(1)(b) requires that personal data be “collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes”. Singapore’s Personal Data Protection Act 2012 section 18 permits an organisation to “collect, use or disclose personal data about an individual only for purposes — (a) that a reasonable person would consider appropriate in the circumstances”. NIST SP 800-53 Rev. 5 carries the same rule into a control catalogue at PT-3, which requires the purposes to be identified, documented, described in the organisation’s public notices, and processing restricted “to only that which is compatible with the identified purpose(s)”.

What none of it reaches is the rung this is about. Each of those obligations binds an organisation’s processing as a matter of law, and each is discharged by a written purpose and a policy against departing from it — which is a rule that holds while people remember it and choose to follow it. None requires that the system holding the record refuse the second use to the party who holds the record. The AI-specific instruments do not close the distance either: the EU AI Act’s logging provisions require the logs of a high-risk system to be generated and kept, and set no limit on their use, deferring the question outward — Article 19(1) keeps them “of at least six months, unless provided otherwise in the applicable Union or national law, in particular in Union law on the protection of personal data”. Its one workplace-specific provision, Article 26(7), is a notice duty: “deployers who are employers shall inform workers’ representatives and the affected workers that they will be subject” to the system. Being told is not a limit.

A specification fails this when the purpose a governance record is held for is not recorded with the record, or nothing refuses its use as a standing measure of the individuals it names — their performance, their ranking, their appraisal — as distinct from establishing who authorised or accepted a particular action, or that refusal rests only on a policy the holder of the record may set aside.

Placing a constraint: the one-page test

A board can agree with every principle above and be exactly where it started. This is the part that moves.

Take **one** constraint the board has actually approved — a payment ceiling, an approval threshold, a category of action a system may not take unsupervised. Not the whole estate; one constraint. Then ask four questions in order, of management, and require the artefact rather than the assurance.

#	Ask	Accept as an answer	Rung it establishes
1	<i>Where is this constraint written, and what reads it?</i>	The artefact itself, and the name of the component that reads it at run time. “It’s in the policy” answers only the first half.	Stated if nothing reads it
2	<i>Can the thing it constrains change it, disable it, or route around it?</i>	A demonstration, not an assertion. Who can edit the file, the prompt, the config, the flag — and is that the same party the constraint binds?	Instructed if yes
3	<i>Show me the last time it stopped something.</i>	A dated instance. If it has never stopped anything, ask when it was last exercised deliberately. Never-fired and never-tested is not a control.	Enforced if it can be shown
4	<i>Could someone outside this organisation confirm that, without trusting us?</i>	A record whose integrity does not rest on the word of the party it would incriminate.	Evidenced , the separate question

Reading the result. A constraint at Stated or Instructed is one the board has approved and nothing holds. That is not a finding about technology; it is a finding about what the board’s approval currently means. Most organisations discover that constraints they believe

are enforced are instructed, and that the drift happened without a decision.

The second question a board asks is always cost, and this document should say so. Moving one constraint from Instructed to Enforced is usually cheap — the enforcement point often already exists and is not being used. Moving it to evidenced is not: it requires a record whose integrity is independent of the producer, and that is an engineering commitment with running cost. **The honest sequence is to enforce broadly and evidence narrowly**, starting with the constraints whose failure you would have to disclose.

What not to do with this. Do not run it across every constraint at once and produce a coverage percentage. A coverage number invites the reporting of progress rather than the fixing of controls, which is principle 22's failure mode arriving through the front door.

What this document does not claim

Four things a board must attend to are **not** in this document, deliberately, and their absence is the boundary rather than an omission:

- **Whether an obligation attaches to you today.** That is counsel's question.
- **How the workforce transition is owned and staffed.** That is the board's and its committees'.
- **Supplier concentration and costed exit.** Third-party risk and operational resilience, already prescribed in detail by financial regulators.
- **Whether a board's oversight would satisfy a regulator.** Counsel's, again.

Each was tested against this document's own scope statement and failed it. Keeping them out is not modesty; a standards body that tells a director what their fiduciary duty requires has exceeded its competence and is less authoritative for having tried.

What would falsify this

- **On enforcement.** If organisations that hold constraints at the Enforced rung grant authority wider than their approved position at the same rate as organisations holding them at Instructed, then the distinction at the centre of this document is descriptive and not causal.
- **On evidence.** If a genuine record's origin can be altered by a third party without detection, or a swapped origin passes full verification, the evidence principles do not deliver what they say. Note what is deliberately **not** on this list: a fabricated origin passing verification. We say plainly that no signature scheme prevents that.

- **On observability.** If the machine layer’s observability does not change the equilibrium the decoupling literature describes — if organisations with mechanically checkable controls exhibit constraint theatre at the same rate as those without — then principle 22’s contribution is nil and the term is borrowed without earning.
- **On over-constraint.** Principle 26 rests on two claims, and the second is the weaker. The first — that an authority set below the work is a failure of the authority — is falsified if organisations that state a floor beneath each grant find no more inoperable authorities than organisations that state none. The second is that this failure does not surface by itself, and it is the one to attack: if the work not done under a too-tight grant produces incident reports, escalations or exception requests at a rate comparable to the work refused under a too-wide one, then nothing has to be built to detect it, and the principle asks for an instrument the organisation did not need.
- **On repurposing.** Principle 27 claims that a record read against the people in it stops describing what happened. It is falsified if the content of governance records is indistinguishable between organisations that use them in appraisal and organisations that do not — and the sharpest single measure is the rate at which an objection is recorded and then overruled, because that is the entry the principle says such a record most reliably deters. If that rate does not fall, the mechanism is not there.

The first and third require deployment data that does not yet exist. They are stated now so that the evidence, when it arrives, settles the question rather than being read to fit.

Version History

Version	Date	Changes
1.0	September 2026	First publication of the corpus. Carries the twenty-seven principles as established in the Foundation’s anchor on 27 August 2026, with two passages of unpublished third-party text removed and their attribution retained.

The Terrene Expert Corpus is published by the Terrene Foundation under CC BY 4.0. The Foundation is a Singapore company limited by guarantee. It publishes open standards and reference implementations; services against those standards are delivered by independent commercial entities, not by the Foundation.

Cite as: Hong, J. (2026g). The Expert Corpus: From Decision to Control. White Paper Series, Version 1.0. Terrene Foundation.

See also: Hong, J. (2026a). CARE: A Core Thesis, for governance philosophy. Hong, J. (2026b). EATP: A Core Thesis, for trust verification. Hong, J. (2026c). CO: A Core Thesis, for methodology. Hong, J. (2026f). PACT: A Core Thesis, for organizational architecture.